

Insurance & Cybersecurity Safeguards — Advisory Memo

Advisory only — not legal, tax, or insurance advice. Coverage needs and security obligations depend on your entity, revenue, staffing, and jurisdiction. Get quotes and guidance from a **licensed insurance broker** and confirm legal obligations with counsel.

This memo outlines the insurance coverages and security/organizational safeguards that typically protect an early-stage SaaS platform like Cirqlback and its owners. It's organized as **essential first, then beneficial**, with a prioritized action list at the end.

Part A — Insurance

Essential (get quotes now)

Coverage	What it protects against	Why it matters for Cirqlback
General Liability (GL)	Third-party bodily injury / property damage claims	Baseline coverage; often required by partners/landlords. Cheap.
Technology E&O / Professional Liability	Claims that your software or service failed, caused a loss, or didn't perform as promised	You run software businesses rely on (rewards, payouts, campaigns). This is the core coverage for a SaaS. Often bundled with Cyber .
Cyber Liability	Data breach, ransomware, business-email compromise, breach-notification costs, forensics, legal defense, regulatory fines where insurable	You hold user emails, tap/activity data, and move money via Stripe. A breach's notification + forensic costs alone can be severe. This is the single most important coverage for a data platform.

A **Business Owner's Policy (BOP)** often bundles GL + property affordably; Tech E&O + Cyber are frequently sold together for tech companies. Ask your broker for a **"tech / SaaS package."**

Beneficial (add as you grow / take on staff or investors)

Coverage	What it protects against	When to consider
Directors & Officers (D&O)	Claims against owners/officers for management decisions	Before raising investment or adding a board/officers. Investors often require it.
Employment Practices Liability (EPLI)	Claims of discrimination, harassment, wrongful termination	When you hire W-2 employees.
Commercial Crime / Fidelity	Employee/contractor theft, funds fraud, social-engineering payment fraud	Relevant because you facilitate payouts/settlements between businesses.
Commercial Property	Damage to your owned equipment/office	If you have an office or valuable hardware.
Commercial Auto / Hired & Non-Owned Auto	Vehicle liability	If anyone drives for the business. Coordinators use their own vehicles and should carry their own auto insurance (state in their contract).
Workers' Compensation	Employee workplace injury	Legally required in most states once you have W-2 employees. Generally not owed for genuine independent contractors — another reason correct classification matters.

Insurance notes specific to your model

- **Coordinators are contractors, not employees** — so you generally don't owe them workers' comp or provide their insurance. Your contractor agreement should (and does) recommend they carry their own coverage. Misclassification can pull them under your obligations, so keep the relationship genuinely independent.
 - **Money movement.** Because you facilitate funded-campaign settlements and Stripe Connect payouts, mention this to your broker (crime/fidelity and cyber coverage for funds-transfer fraud) **and** to counsel (money-transmission/facilitator structuring).
 - **Contracts + insurance work together.** The limitation-of-liability and indemnity clauses in your Terms/agreements reduce what insurance must absorb. Keep both.
-

Part B — Cybersecurity & data safeguards

Many of these you already do; the goal is to make them explicit, consistent, and defensible.

1. Payments & PCI

- **Keep card data with Stripe.** Never store raw card numbers; use Stripe's hosted/tokenized flows so you stay in the smallest PCI scope (SAQ-A). Confirm no logs capture card data.
- Reconcile Stripe webhooks server-side (you already verify signed webhooks) so payment state can't be spoofed by the browser.

2. Access & secrets

- **MFA everywhere** — on your email, domain registrar, GitHub, Render, Neon, Stripe, and Google Cloud. These are the keys to the kingdom.
- **Least privilege** — limit who has admin/production access; use per-person accounts, not shared logins.
- **Secrets management** — keep API keys in the host's environment (not in git). **Rotate** keys periodically and immediately if exposed. (You already rotated Maps keys; extend the habit to Stripe/OpenAI/DB.)
- **Admin controls** — you already have admin roles, an audit log, user suspend, and session-based impersonation. Ensure impersonation and privileged actions stay logged (they are) and reviewed.

3. Data protection

- **Encryption in transit** (HTTPS/TLS everywhere — you have HSTS) and **at rest** (Neon/Postgres and backups).
- **Data minimization** — you already favor anonymous customers and optional email; keep collecting the minimum.
- **Backups + tested restore** — ensure the database has automated backups **and periodically test restoring one**. A backup you've never restored is a hope, not a plan.

4. Application & infrastructure hardening

- You already run **helmet** (security headers), **CORS** locking in prod, and **rate limiting** — keep them on.
- **Dependency/patch management** — enable automated dependency alerts (e.g., GitHub Dependabot) and update promptly.
- **Input validation** — you validate with zod on new endpoints; keep that standard and use parameterized queries (Drizzle) to avoid injection.
- **Logging, monitoring, alerting** — centralize logs and alert on errors, auth failures, and unusual payout/settlement activity.
- **Domain/email security** — enable **SPF, DKIM, and DMARC** on your sending domain to prevent spoofing/business-email compromise; lock the domain registrar with MFA and registrar-lock.

5. People & process

- **Security in contracts** — confidentiality and data-use terms for coordinators/contractors (in the agreements) plus **Data Processing Agreements (DPAs)** with vendors (Stripe, hosting, AI, maps).
- **Written policies** — a short **Incident Response Plan** (who does what in a breach, how you notify users/regulators) and an internal security/acceptable-use policy. Even a one-pager is far better than nothing and is expected by cyber insurers.
- **Breach notification** — nearly every U.S. state requires notifying affected users (and sometimes regulators) after a breach of personal data, often within a set timeframe. Your IR plan should reference this; counsel can map the specifics.

- **Vendor review** — keep a list of subprocessors and confirm each is reputable and compliant (Stripe = PCI Level 1; your host; your AI provider).

6. As you scale (beneficial)

- **Penetration test / security review** once you have meaningful traffic or before a big partner/enterprise deal.
 - **SOC 2 Type II** — a formal audit some larger customers/partners require. Not needed early, but design your controls now so it's cheaper later.
 - **Bug-bounty or vulnerability-disclosure page** — a simple "security@" contact and policy.
-

Part C — Organizational safeguards for the owners

- **Operate through a formal entity** (LLC or corporation) and **respect the corporate veil** — separate bank accounts, don't commingle personal and business funds, keep records, sign contracts in the entity's name. This is a primary shield for the owners' personal assets.
 - **Keep the contracts current** — Terms, Privacy, Merchant, and Coordinator agreements are part of your risk defense; review them at least annually and after major feature changes.
 - **Cap-table / IP hygiene** — ensure all IP (including contractor Deliverables) is assigned to the company (the contractor agreement does this).
 - **Records retention** — keep tax, payout, and consent records for the periods your CPA/attorney advise.
-

Prioritized action list

1. **Get insurance quotes** for a SaaS package: **Tech E&O + Cyber Liability** (top priority) and **General Liability / BOP**. Mention funds facilitation for crime/fidelity.
 2. **Turn on MFA** across email, domain registrar, GitHub, Render, Neon, Stripe, Google Cloud — today.
 3. **Confirm backups exist and test a restore.**
 4. **Rotate and inventory secrets;** confirm none are in git.
 5. **Enable SPF/DKIM/DMARC** and registrar-lock on the domain.
 6. **Write a one-page Incident Response Plan** and a short internal security policy (insurers ask for these).
 7. **Sign DPAs** with Stripe and your other vendors.
 8. **Confirm entity formation + separate finances** with your attorney/CPA.
 9. **Enable dependency alerts** (Dependabot) and a patch cadence.
 10. **Revisit** this list and the legal pack **annually** and before major launches.
-

This memo is advisory and general. Confirm insurance needs with a licensed broker and legal/compliance obligations with an attorney.